



Instituto Politécnico Nacional
Escuela Superior de Cómputo



Ingeniería en Sistemas Computacionales
Academia de Sistemas Distribuidos

Unidad de Aprendizaje:
Gobierno de TI | Computer Security

Tarea 13: “Pruebas de penetración en escenarios de
amenazas”

Luis Andrés Contla Mota

2022630540

6CV4

Profesor:

MBA. Rodrigo Ojeda Santillán

Pruebas de penetración

Las pruebas de penetración (pentesting) son evaluaciones autorizadas donde profesionales éticos simulan ataques para identificar vulnerabilidades antes de que atacantes las exploten. [1][2] Siguen cinco fases: reconocimiento, escaneo, explotación, post-explotación y report. [3] Proporcionan evaluación realista de seguridad, identificando vectores de ataque y ofreciendo recomendaciones de remediación. [4][5]. Son fundamentales para cumplimiento regulatorio y validación de controles. [6]

Fase 1: Reconocimiento (Reconnaissance)

El reconocimiento recompila información sobre el objetivo sin interacción directa. [1][3]. Se divide en pasivo (búsquedas públicas, redes sociales) y activo (consultas DNS, escaneo inicial) [2][4]. Herramientas: Nmap (descubrimiento), Maltego (OSINT), Shodan (dispositivos), The Harvester (correos), Recon-ng (automatización) [5][6]. Identifica puntos de entrada y construye perfil detallado del objetivo [1][3].

Fase 2: Escaneo (Scanning)

El escaneo identifica puertos abiertos, servicios y vulnerabilidades activamente. Utiliza técnicas como escaneo TCP/UDP, detección de versiones y enumeración de sistemas. [3][5].

Herramientas: Nmap (red/servicios), Nessus (vulnerabilidades), OpenVAS (scanner), Nikto (web), Masscan (escaneo rápido), Produce inventario de assets, servicios expuestos y vulnerabilidades para la siguiente fase.

Fase 3: Explotación (Exploitation)

La explotación aprovecha vulnerabilidades para obtener acceso no autorizado. Utiliza exploits públicos o personalizados para validar impacto real. [2][5].

Herramientas: Metasploit Framework (plataforma integral), SQLmap (SQL injection), Burp Suite (web apps), Exploit DB (repositorio), BeEF (navegadores) [4][6]. Demuestra profundidad de penetración y datos sensibles comprometidos. [1][5]

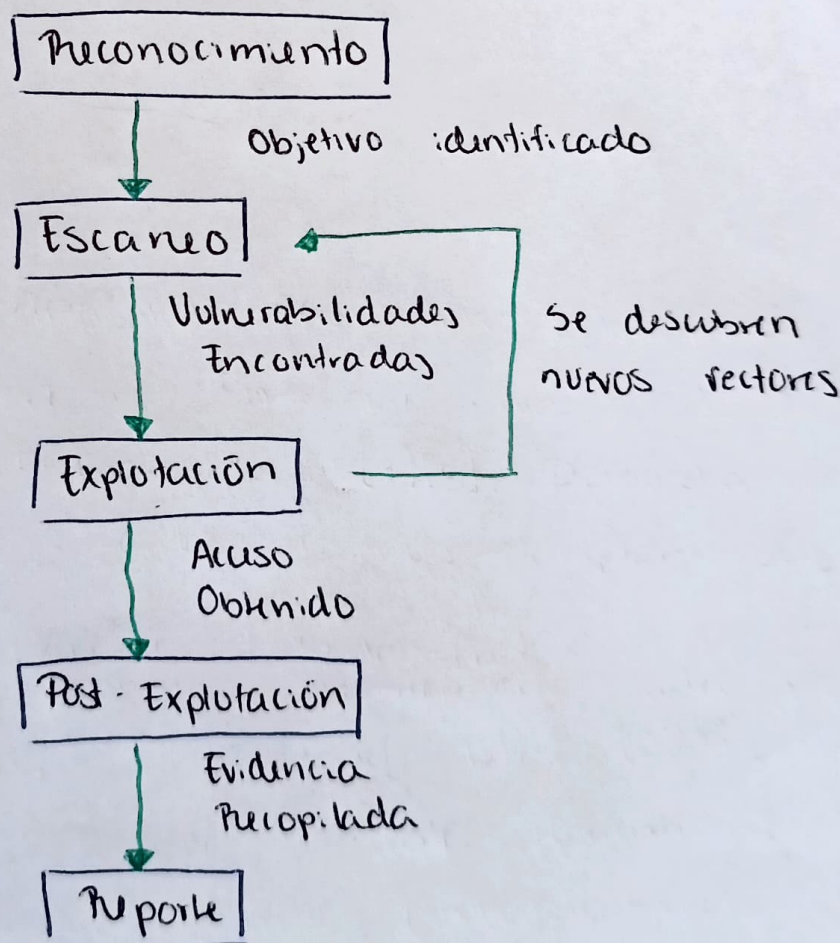
Fase 4: Post-Explotación (Post-Exploitation)

La post-Explotación mantiene persistencia, escala privilegios, se mueve lateralmente y extrae datos. [2][4]. Simula acciones reales de un atacante. Herramientas: Mimikatz, Bloodhound, Empire/Covenant, LinPEAS/WinPEAS, Netcat, Powersploit [5][6]. Valida el alcance del daño potencial.

Fase 5: Reporte (Reporting)

El report documenta vulnerabilidades con severidad, evidencias y remediación [1][3]. Incluye: resumen ejecutivo, metodología, clasificación CVSS, evidencias visuales, evaluación de riesgo y recomendaciones priorizadas. [2][4][5]. Debe ser accionable para replicar hallazgos y aplicar correcciones. [6]. Es la entrega formal al cliente con pasos técnicos específicos.

Flujo de las fases



Referencias

- [1]. EC-Council. (2022). Learn About The Five Penetration Testing Phases. Recuperado de <https://www.eccouncil.org/cybersecurity-exchange/penetration-testing/penetration-testing-phases/>
- [2]. Invicti. (2025). 5 Stages of Penetration Testing Explained. Recuperado de <https://www.invicti.com/blog/web-security/5-stages-of-penetration-testing>
- [3]. Beagle Security. (2025). The 5 essential phases of penetration testing. Recuperado de <https://beaglesecurity.com/blog/article/penetration-testing-phases.html>
- [4]. StationX. (2025). Penetration Testing Steps: A Comprehensive Guide. Recuperado de <https://www.stationx.net/penetration-testing-steps/>
- [5]. eSecurityPlanet. (2025). Penetration Testing Phases: Steps, Tools & Methodology. Recuperado de <https://www.esecurityplanet.com/networks/penetration-testing-phases/>
- [6]. Qualysec. (2025). What are the 7 Phases of Penetration Testing? Recuperado de <https://qualysec.com/penetration-testing-phases/>